

## Bypass of jinja2 SSTI in mlflow/mlflow

✓ Valid

Reported on Dec 12th 2023

### Description

From [previous report](#) the SSTI still exists because of an invalid fix.

the [fix PR](#) is not related to [the vulnerability](#) that found by @kevin-mizu. the actual use of `SandboxedEnvironment` should be [here](#)

Also, you disclosed the vulnerability but you forgot to contain the fix commit into `MLflow 2.9.1` which had been released on the same day of the fix commit, So the latest mlflow is vulnerable and still, we have a disclosed vulnerability (besides that the fix has not been successful).

### Impact

with only one user interaction(download a malicious config), attackers can gain full command execution on the victim system.

### Occurrences

 `file_utils.py L341`

 We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago



 **Am** modified the report 2 years ago



 **Am** modified the report 2 years ago



 **Am** modified the report 2 years ago



**Ben Wilson** commented 2 years ago

Maintainer

Hi @am0o0, I've just filed this PR: <https://github.com/mlflow/mlflow/pull/10676> can you verify that this fixes the SSTI vulnerability?

flow



A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago



**Am** commented 2 years ago

Researcher

Yes, I confirm this fix.

thanks for the quick response!



**Ben Wilson** validated this vulnerability 2 years ago

\$ **am0o0** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



**Ben Wilson** marked this as fixed in **2.9.2** with commit **5139b1** 2 years ago

\$ **Ben Wilson** has been awarded the fix bounty ✓



This vulnerability has now been published 2 years ago

\$ **file\_utils.py#L341** has been validated ✓

[Sign in](#) to join this conversation

## CVE

CVE-2023-6940

Published

## Vulnerability Type

CWE-77: Command Injection

## Severity

Critical (9)

|                     |          |
|---------------------|----------|
| Attack vector       | Network  |
| Attack complexity   | Low      |
| Privileges required | Low      |
| User interaction    | Required |
| Scope               | Changed  |
| Confidentiality     | High     |
| Integrity           | High     |
| Availability        | High     |

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

\*

Visibility

Public

Status

Fixed

Disclosure Bounty

\$1500

Fix Bounty

\$375

Found by



Am

@am0o0

LIGHTWEIGHT



Fixed by



Ben Wilson

@benwilson2

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)